ЗВІТ

з лабораторної роботи № 3

з дисципліни «Проектування, розробка і реалізація криптографічних систем»

на тему: «Дослідження криптографічних протоколів
та механізмів захисту платіжних систем»

Виконала:
студентка групи ФІ-52мн
Балацька Вікторія

Київ — 2026

1. Мета роботи

Дослідження принципів побудови сучасних електронних платіжних систем, криптографічних механізмів захисту платіжних операцій та основних загроз, що виникають під час здійснення електронних платежів.

2. Відповіді на питання щодо механізмів захисту електронних платежів

2.1. Учасники карткового платежу в Інтернеті

Учасник	**Функції**
Покупець (держатель картки)	Ініціює платіж, вводить реквізити картки або використовує гаманець/токен, проходить автентифікацію в банку-емітенті (3-D Secure, SCA).
Продавець (merchant)	Формує замовлення і суму, передає покупця на платіжну форму провайдера, отримує результат оплати й відвантажує товар. У сучасних схемах не обробляє повний номер картки, а працює з токеном.
Платіжний провайдер (PSP) / еквайр	PSP надає платіжну форму, API, токенізацію, антифрод, 3DS-сервер; еквайр — банк, що має договір з продавцем, надсилає запити авторизації в платіжну систему, отримує відшкодування і зараховує кошти продавцю.
Платіжна система (Visa, Mastercard, НПС «ПРОСТІР»)	Встановлює правила та стандарти, маршрутизує авторизаційні запити між еквайром і емітентом (Directory Server 3DS, Token Service Provider), виконує клірінг і розрахунки, розглядає спори (chargeback).
Банк-емітент	Випустив картку і веде рахунок; автентифікує держателя (ACS 3DS, застосунок банку), ухвалює рішення про авторизацію (баланс, ліміти, ризики), списує кошти, несе відповідальність перед клієнтом.

Таблиця 1 — Учасники карткового платежу

2.2. Автентифікація користувача та авторизація операції

Автентифікація відповідає на питання «хто це?» — перевірка того, що операцію ініціює законний держатель картки чи рахунку (пароль, одноразовий код, біометрія, криптографічний ключ пристрою). Виконується банком-емітентом або надавачем платіжних послуг. **Авторизація платіжної операції** — рішення «чи дозволено провести саме цю операцію?»: емітент перевіряє статус картки, наявність коштів, ліміти, результати антифрод-аналізу, результат автентифікації, і повертає схвалення (код авторизації) або відмову. Успішна автентифікація не гарантує авторизації (може не вистачити коштів), а авторизація без автентифікації можлива (винятки з SCA), але тоді ризик шахрайства зазвичай несе продавець або еквайр.

2.3. Роль TLS в електронному платежі

TLS захищає канали «браузер/застосунок ↔ продавець», «браузер ↔ платіжна форма PSP», «продавець ↔ API PSP», «3DS-сервер ↔ Directory Server ↔ ACS» (часто з взаємною автентифікацією mTLS). Забезпечує: конфіденційність реквізитів картки та кодів у мережі; цілісність (неможливо непомітно змінити суму чи реквізити в

каналі); автентифікацію сервера (покупець справді на сторінці PSP, а не на підробленій). Захищає від прослуховування (Wi-Fi, провайдер), модифікації трафіку, MITM, SSL stripping (разом з HSTS). **Не захищає** від компрометації кінцевих точок: шкідливого JavaScript на сторінці магазину (web-skimming/Magecart), фішингового сайту з дійсним сертифікатом, крадіжки даних із бази продавця, використання вкрадених реквізитів.

2.4. Токенізація платіжних реквізитів

Токенізація — заміна номера картки (PAN) на замінник (токен), що не має самостійної цінності і не дозволяє обчислити PAN. Відповідність «токен ↔ PAN» зберігається лише в захищеному сховищі (token vault) постачальника токенів. Розрізняють **токени PSP** (для збереженої картки продавця, придатні лише в цього PSP і для цього продавця) та **мережеві токени** за стандартом EMV Payment Tokenisation (видає Visa VTS / Mastercard MDES; обмежені доменом — пристрій, продавець, канал; кожна операція супроводжується одноразовою криптограмою).

- Витік бази продавця не розкриває PAN — токен без доступу до vault і поза своїм доменом непридатний.
- Скорочується область дії PCI DSS для продавця: він не зберігає і не обробляє дані держателя картки.
- Мережевий токен автоматично оновлюється при перевипуску картки (менше відмов у повторних платежах) і може бути відкликаний окремо від картки.
- Криптограма на кожну операцію унеможливлює повторне використання перехопленого токена.

2.5. Призначення CVV/CVC і вимоги до зберігання

CVV2/CVC2 — 3–4-значний код на картці (не записаний на магнітній смузі чи в чипі), який обчислюється емітентом із PAN, строку дії та сервісного коду на секретних ключах (3DES/AES). Використовується в операціях без присутності картки (card-not-present) як доказ того, що платник фізично має картку, а не лише знає номер. Оскільки CVV2 разом з PAN і строком дії достатньо для оплати в Інтернеті, він належить до **чутливих автентифікаційних даних (SAD)**. PCI DSS (вимога 3.3.1.2) забороняє зберігати його після авторизації навіть у зашифрованому вигляді. Тому витік бази продавця без CVV2 значно менш цінний для зловмисника, а повторні платежі проводяться за токенами і без CVV2.

2.6. Призначення 3-D Secure

3-D Secure (EMV 3DS 2.x; бренди Visa Secure, Mastercard Identity Check) — протокол, що переносить **автентифікацію держателя картки до банку-емітента** в режимі онлайн-платежу. Три домени: емітента (ACS — Access Control Server), еквайра (3DS Server продавця/PSP) і взаємодії (Directory Server платіжної системи). PSP

надсилає емітенту понад 100 параметрів операції та пристрою. Емітент оцінює ризик і або автентифікує без участі клієнта (**frictionless**), або вимагає підтвердження (**challenge**: push у банківському застосунку з біометрією, OTP). Результат підтверджується криптографічним значенням CAVV/AAV (MAC на ключах емітента), яке додається до запиту авторизації і перевіряється емітентом. Додаткова автентифікація: (1) запобігає використанню вкрадених реквізитів картки без другого фактора; (2) забезпечує виконання вимог SCA (постанова НБУ № 58, PSD2); (3) переносить відповідальність за шахрайську операцію з продавця на емітента (liability shift).

2.7. Вимоги посиленої автентифікації за постановою НБУ № 58

Постанова Правління НБУ від 03.05.2023 № 58 затверджує Положення про автентифікацію та застосування посиленої автентифікації на платіжному ринку. Основні вимоги:

- **Посилена автентифікація** — застосування двох або більше елементів різних категорій: знання (пароль, PIN), володіння (телефон з застосунком, картка, токен) та притаманності (біометрія). Елементи мають бути незалежними: компрометація одного не повинна порушувати надійність інших.
- **Обов'язкове застосування:** дистанційний доступ користувача до рахунку; ініціювання дистанційної платіжної операції; дії, що можуть свідчити про ризик шахрайства.
- **Динамічне зв'язування:** за результатом автентифікації формується унікальний код автентифікації, прив'язаний до суми операції та отримувача; зміна будь-якого з них робить код недійсним. Платнику відображаються сума і отримувач.
- **Обмеження спроб і сесій:** кількість послідовних невдалих спроб — не більше п'яти (після цього — блокування); час неактивності в дистанційній сесії — не більше 10 хвилин.
- **Вичерпний перелік винятків**, коли посилену автентифікацію можна не застосовувати: дистанційні операції на невелику суму (у Положенні — до 2 000 грн за умови, що накопичена сума не перевищує 10 000 грн або кількість послідовних операцій без SCA не перевищує п'яти); операції на користь довірених отримувачів; наступні операції в серії регулярних платежів; операції з низьким рівнем ризику за результатами аналізу ризиків (коли рівень шахрайства надавача нижче референтних значень); окремі платежі до бюджету та за комунальні послуги. Створення або зміна переліку довірених отримувачів чи серії регулярних платежів потребує посиленої автентифікації.
- **Організаційні вимоги:** механізми моніторингу шахрайства, захист елементів автентифікації та каналів зв'язку, контроль за ризиками, звітування НБУ.

Вимоги щодо електронної взаємодії надавачів (відкриті API) набули чинності з 01.08.2025.

2.8. Цифровий підпис і HMAC у взаємодії компонентів

Між компонентами платіжної системи (магазин ↔ PSP, PSP ↔ еквайр, еквайр ↔ платіжна система, ACS ↔ Directory Server) повідомлення проходять через кілька систем і сховищ, тому захисту лише каналу (TLS) недостатньо — потрібен захист **самого повідомлення**, що зберігається після завершення TLS-сесії. **HMAC** (на спільному секреті) використовують для підпису API-запитів продавця і вебхуків PSP, у форматі MAC повідомлень ISO 8583 між банками, у криптограмі EMV (ARQC) і CAVV. Він забезпечує цілісність і автентичність джерела, але не неспростовність (ключ знають обидві сторони). **Цифровий підпис** (RSA, ECDSA) дає неспростовність і дозволяє перевірку будь-якій стороні без спільного секрету: підпис повідомлень 3DS і сертифікати Directory Server, підписані токени Apple Pay/Google Pay, JWS у Open Banking, кваліфіковані підписи платіжних доручень. Разом з мітками часу і nonce обидва механізми захищають і від повторного відтворення. Практичну демонстрацію наведено в п. 4.3–4.4.

2.9. Призначення стандарту PCI DSS

PCI DSS (Payment Card Industry Data Security Standard, чинна версія 4.0.1, 2024 р., обов'язкові вимоги v4.0 — з 31.03.2025) — стандарт PCI Security Standards Council, обов'язковий для всіх організацій, що зберігають, обробляють або передають дані платіжних карток (продавці, PSP, еквайри, процесингові центри, постачальники послуг). Захищає:

- **Дані держателя картки (CHD):** PAN, ім'я, строк дії, сервісний код — можна зберігати лише за потреби, PAN — у нечитабельному вигляді (шифрування, токенізація, усічення, хешування з ключем).
- **Чутливі автентифікаційні дані (SAD):** повні дані смуги/чипа, CVV2/CVC2, PIN і PIN-блок — зберігати після авторизації заборонено.
- **Компоненти середовища даних держателів карток (CDE):** сервери, бази даних, мережеве обладнання, платіжні сторінки та скрипти на них, POS-термінали, а також системи, що з ними з'єднані.

12 вимог згруповано в 6 цілей: захищена мережа (межмережеві екрани, безпечні конфігурації), захист даних (шифрування при зберіганні та передаванні), керування вразливостями, контроль доступу (мінімальні привілеї, MFA для доступу до CDE), моніторинг і тестування (журнали, сканування, пентести, контроль змін платіжних сторінок — вимоги 6.4.3 і 11.6.1 проти web-skimming), політика безпеки.

3. Схема проведення електронного платежу та результати її аналізу

Розглянуто типовий сценарій: покупець оплачує замовлення в інтернет-магазині банківською карткою через платіжну форму PSP з 3-D Secure 2.

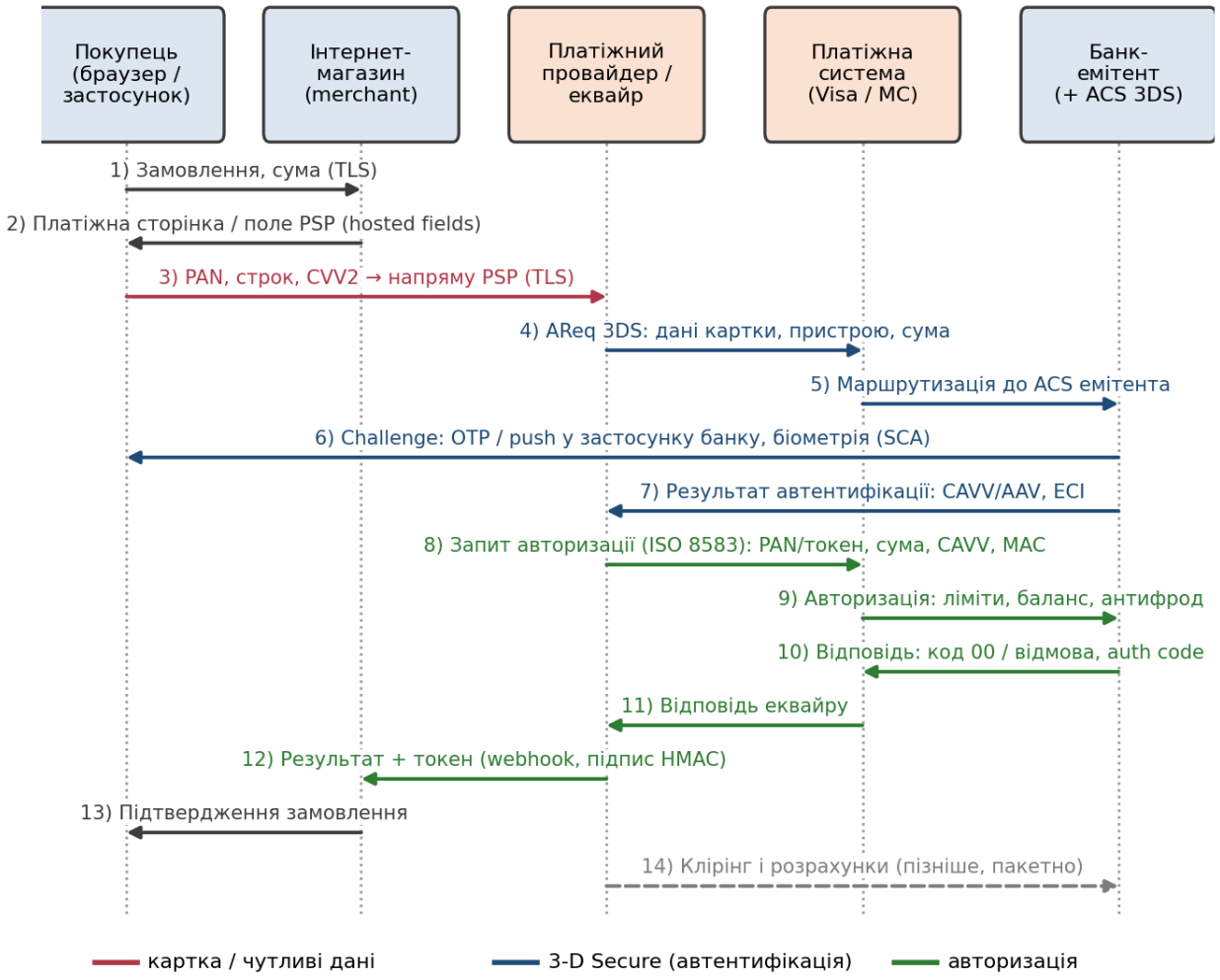


Рисунок 1 — Спрощена схема проведення карткового платежу в Інтернеті

Етап	Дані, що передаються	Хто має доступ	Що потребує захисту	Механізми захисту
1–2. Оформлення замовлення	Товари, сума, валюта, ID замовлення, контакти	Покупець, магазин	Цілісність суми, конфіденційність персональних даних	TLS 1.2/1.3, HSTS; підпис параметрів замовлення HMAC магазином для PSP
3. Введення реквізитів	PAN, строк дії, CVV2, ім’я	Покупець → PSP (магазин не бачить при hosted-формі / iframe)	Конфіденційність і цілісність PAN, CVV2 — найчутливіші дані	TLS до PSP, hosted fields, CSP і контроль скриптів (PCI DSS 6.4.3), токенізація відразу після введення
4–7. 3-D Secure	Дані картки, пристрою, суми; результат автентифікації (CAVV, ECI)	PSP (3DS Server), платіжна система (DS), емітент (ACS)	Цілісність і автентичність повідомлень, приватність даних пристрою	mTLS між доменами, підписи JWS, CAVV — MAC на ключах емітента, одноразові коди/push

Етап	Дані, що передаються	Хто має доступ	Що потребує захисту	Механізми захисту
8–11. Авторизація	PAN або токен, сума, merchant ID, CAVV, криптограма, код відповіді	Еквайр, платіжна система, емітент	Цілісність суми й отримувача, захист від повтору	Виділені захищені канали, MAC ISO 8583, HSM, шифрування PIN/даних на ключах зон (TPK/ZPK/ZEK), STAN і номер трасування
12–13. Результат	Статус, код авторизації, токен картки	PSP, магазин, покупець	Автентичність сповіщення (щоб не «оплатити» підробленим вебхуком)	Підпис вебхуку HMAC/ЕЦП, перевірка статусу через API, ідемпотентність
14. Клірінг і розрахунки	Реєстри операцій, суми	Еквайр, платіжна система, емітент	Цілісність і повнота	Захищені канали, звірка, підписані файли

Таблиця 2 — Аналіз етапів проведення платежу

Автентифікація користувача відбувається на етапі 6: емітент (ACS) у frictionless-режимі на основі аналізу ризиків або в режимі challenge через банківський застосунок (володіння пристроєм + біометрія/PIN), тобто за правилами посиленої автентифікації. **Підтвердження або відхилення** операції здійснює емітент на етапі 9: перевірка CAVV, статусу картки, коштів, лімітів і антифрод-скорингу. Результат — код відповіді (00 — схвалено, 05, 51 тощо — відмова), який через платіжну систему та еквайра доходить до магазину. Кошти на цьому етапі блокуються (холд), а фактичне списання відбувається під час клірінгу.

Чому TLS сам по собі не вирішує задач захисту платіжної системи:

- TLS захищає лише дані в дорозі між двома вузлами; на кожній кінцевій точці (браузер, сервер магазину, PSP) дані знову відкриті. Скомпрометований сайт магазину (web-skimming) краде реквізити до шифрування.
- TLS автентифікує сервер, а не платника: він не доводить, що реквізитами користується власник картки. Для цього потрібні 3-D Secure та SCA.
- TLS не забезпечує наскрізної цілісності через кілька проміжних систем і не дає неспростовності — потрібні HMAC/цифрові підписи на рівні повідомлень.
- TLS не захищає дані при зберіганні: базу продавця захищають токенізація, шифрування і вимоги PCI DSS.
- TLS не запобігає логічним атакам на рівні застосунку: повтору запиту, зміні суми до відправлення, шахрайству з вкраденими реквізитами, фішингу на сайті з дійсним сертифікатом.

4. Аналіз ситуацій порушення безпеки

4.1. Ситуація 1. Перехоплення мережевого трафіку

Що може отримати зловмисник при коректному HTTPS/TLS: IP-адреси сторін, доменне ім'я магазину і PSP (з SNI та DNS, якщо не використовуються ECH і DoH), час, тривалість, обсяг і розміри пакетів (за якими можна приблизно визначити дії — наприклад, факт відвідування платіжної сторінки), параметри рукостискання. **Не може отримати:** URL-шлях, cookie, реквізити картки, CVV2, суму, OTP, вміст відповіді — вони зашифровані AEAD-шифром з ключами, узгодженими через ECDHE (Forward Secrecy захищає і від подальшої компрометації ключа сервера).

TLS захищає від: пасивного прослуховування реквізитів, модифікації даних у каналі (зміни суми, отримувача), підміни сервера (MITM), повтору записів TLS. **Наслідки:** витік метаданих, профілювання поведінки — низький рівень ризику для коштів. **Додаткові механізми:** HSTS (preload) проти SSL stripping, TLS 1.3, Encrypted Client Hello, DNS over HTTPS, certificate pinning у мобільних застосунках.

4.2. Ситуація 2. Компрометація бази даних продавця

Критерій	Магазин зберігав платіжні реквізити	Магазин зберігав лише токени
Що отримав зловмисник	PAN, строки дії, імена; якщо порушено PCI DSS — і CVV2	Токени PSP або мережеві токени, останні 4 цифри, строк дії
Можливість використання	Пряме використання для оплати в Інтернеті (особливо у магазинах без 3DS), продаж у кардинг-базах, фішинг «від банку» з реальними даними	Токен працює лише в межах домену (конкретний магазин + PSP) і лише з ключами магазину в PSP; мережевий токен без криптограми відхиляється. PAN відновити неможливо
Масштаб шкоди	Масовий: усі клієнти, перевипуск карток, chargeback-и	Мінімальний: відкликання токенів, зміна API-ключів у PSP
Відповідальність	Штрафи платіжних систем, розслідування PCI Forensic Investigator, повне PCI DSS-оцінювання, репутаційні втрати, відповідальність за законодавством про захист персональних даних	Інцидент з персональними даними, але не з даними карток; область PCI DSS мінімальна (SAQ A)

Таблиця 3 — Порівняння наслідків компрометації бази продавця

Роль токенізації: вона знецінює вкрадені дані, прибираючи PAN з систем продавця. Секрет зберігається лише в одному місці — у token vault PSP або платіжної системи з HSM, жорстким контролем доступу і аудитом PCI DSS рівня 1. Замість захисту сотень баз продавців треба захистити одне сховище. Токен прив'язаний до домену використання, тож навіть витік токенів разом з базою не дає змоги платити деінде.

4.3. Ситуація 3. Повторне проведення операції

Тип атаки: атака повторного відтворення (**replay attack**) — зловмисник повторно надсилає раніше перехоплене коректне (автентичне) повідомлення. Підпис або MAC його не виявить, бо повідомлення не змінено. **Наслідки:** повторне списання коштів, подвійна відправка товару, порушення балансу. **Механізми запобігання:**

- **Унікальність запиту:** nonce або ідентифікатор замовлення / ідемпотентний ключ (`Idempotency-Key`); сервер зберігає використані значення і відхиляє дублікати.
- **Мітки часу** з обмеженим вікном дійсності (напр., 5 хвилин), включені до даних, що підписуються.
- **Порядкові номери та лічильники:** STAN/RRN в ISO 8583, лічильник операцій чипа ATC, від якого залежить криптограма ARQC — повтор з тим самим ATC відхиляється емітентом.
- **Одноразові криптограми та коди:** криптограма токена/EMV, CAVV 3DS та OTP придатні лише для однієї операції і прив'язані до суми (динамічне зв'язування).
- **TLS:** захищає від повтору на рівні каналу (послідовні номери записів), але не від повтору на рівні застосунку, тому потрібні механізми вище.

Демонстрацію перевірки HMAC, мітки часу та nonce на стороні платіжного сервісу виконано за допомогою скрипта на Python (стандартні модулі `hmac`, `hashlib`, `secrets`):

```
Запит : {"merchant_id": "shop-123", "order_id": "A-10057", "amount": 1499.0, "currency": "UAH",
        "payee_iban": "UA213223130000026007233566001", "ts": 1790439529,
        "nonce": "230144300fff7e20"}
HMAC  : 18de0148cda4193049679cb0fb8dc522e4809ce27989b8b1821327eab0d76175
1) Оригінальний запит           -> ПРИЙНЯТО
2) Повторне надсилання (replay) -> ВІДХИЛЕНО: повторний nonce (replay)
3) Змінена сума 14990.00         -> ВІДХИЛЕНО: невірний HMAC (дані змінено)
4) Запит годинної давнини       -> ВІДХИЛЕНО: застаріла мітка часу
```

Лістинг 1 — Результат виконання демонстраційного скрипта hmac_demo.py

Повторно надісланий оригінальний запит (2) має правильний HMAC, але відхиляється через вже використаний nonce; запит з простроченою міткою часу (4) — через вікно дійсності.

4.4. Ситуація 4. Модифікація параметрів платежу

Модифікація можлива на різних ділянках: у каналі (MITM), на пристрої (шкідливе ПЗ, підміна в браузері — man-in-the-browser), на сервері магазину (зміна IBAN/суми), у зміненому запиті від клієнта (зміна параметра `amount` у формі). **Криптографічні механізми:**

- **TLS —** цілісність у каналі між двома вузлами (AEAD).

- **HMAC / цифровий підпис параметрів** (сума, валюта, отримувач, ID замовлення) на стороні магазину на секреті, недоступному клієнту: PSP перевіряє підпис і відхиляє змінений запит (лістинг 1, випадок 3).
- **MAC повідомлень ISO 8583** між еквайром і емітентом та EMV-криптограма (ARQC), що обчислюється від суми, валюти, дати і випадкового числа терміналу — змінена сума не пройде перевірку емітентом.
- **Динамічне зв'язування (постанова НБУ № 58, 3DS):** код автентифікації прив'язаний до суми і отримувача; зміна будь-якого параметра анулює код.

Прикладні механізми: сума та отримувач формуються лише на сервері (ніколи не довіряти даним клієнта); відображення суми і отримувача в незалежному каналі (push у банківському застосунку «Підтвердіть 1 499 грн — shop-123») — «what you see is what you sign», що протидіє man-in-the-browser; звірка суми при отриманні вебхуку зі значенням у замовленні; перевірка IBAN отримувача (Confirmation of Payee); контроль цілісності скриптів платіжної сторінки (SRI, CSP); антифрод-моніторинг аномалій.

4.5. Ситуація 5. Компрометація облікових даних користувача

Логін і пароль є лише одним елементом категорії «знання». **Багатофакторна автентифікація** вимагає ще елемента іншої категорії — «володіння» (прив'язаний смартфон із ключем у захищеному сховищі, апаратний ключ FIDO2) та/або «притаманності» (біометрія), тому одного пароля недостатньо для входу або платежу. **3-D Secure** додатково переносить автентифікацію карткової операції до емітента: навіть з логіном до інтернет-магазину і реквізитами картки операція потребує підтвердження в застосунку банку, прив'язаного до суми і отримувача (динамічне зв'язування). Незалежність елементів гарантує, що компрометація пароля не розкриває другий фактор.

Ризики, що залишаються:

- **Соціальна інженерія:** зловмисник видає себе за банк і переконує жертву продиктувати OTP або підтвердити push-запит (найпоширеніший сценарій в Україні).
- **Фішинг у реальному часі (AitM):** проксі-сайт (Evilginx-подібні інструменти) передає пароль і OTP у банк та викрадає сесію; від цього захищають лише прив'язані до домену автентифікатори (FIDO2/passkeys).
- **SIM-swap і перехоплення SMS:** SMS OTP — найслабший фактор (перевипуск SIM, SS7).
- **Шкідливе ПЗ на смартфоні** (банківські трояни, зловживання спеціальними можливостями Android): обидва фактори на одному пристрої.
- **MFA fatigue:** багаторазові push-запити, доки користувач не підтвердить.

- **Винятки з SCA:** операції на невеликі суми та з низьким ризиком проходять без другого фактора.
- **Авторизоване шахрайство (APP fraud):** користувач сам підтверджує переказ, будучи обманутим.

Протидія: FIDO2/passkeys замість SMS, відображення суми й отримувача в підтвердженні, поведінкова аналітика та антифрод, обмеження частоти push-запитів, повідомлення про нові пристрої, лімітування операцій, навчання клієнтів.

5. Дослідження сучасного способу електронних платежів: Apple Pay

Як індивідуальний варіант обрано **Apple Pay** (варіант 3).

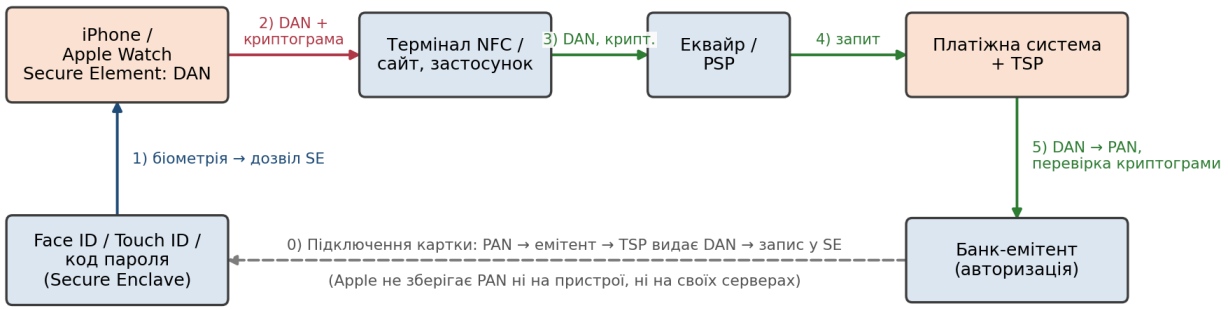


Рисунок 2 — Спрощена схема платежу Apple Pay

Аспект	Apple Pay
Учасники	Користувач і пристрій (iPhone, Apple Watch, Mac); Apple (сервіс підключення карток, сервери для оплат в Інтернеті); продавець (NFC-термінал або сайт/застосунок); PSP / еквайр; платіжна система з Token Service Provider (Visa VTS, Mastercard MDES); банк-емітент.
Дані та криптографічні credentials	Device Account Number (DAN) — мережевий токен замість PAN, унікальний для пристрою; ключі, що їх емітент/TSP записує в Secure Element; одноразова динамічна криптограма для кожної операції; для оплат в Інтернеті — зашифрований платіжний токен (формат EC_v1: ефемерний ключ ECDH P-256, дані в AES-256-GCM, підпис Apple за PKCS#7).
Де зберігається критична інформація	DAN і ключі — у Secure Element (сертифікований чип, недоступний iOS і Apple); біометричні шаблони — у Secure Enclave і не залишають пристрій. PAN не зберігається ні на пристрої, ні на серверах Apple — лише в емітента, а відповідність DAN ↔ PAN — у TSP платіжної системи. Продавець отримує лише DAN (без PAN).
Автентифікація користувача	Face ID / Touch ID або код пароля пристрою (Consumer Device Cardholder Verification Method, CDCVM): Secure Enclave перевіряє біометрію і дозволяє SE сформувати платіж. Разом із володінням пристроєм це дає два фактори (володіння + притаманність/знання), тобто відповідає вимогам посиленої автентифікації. Під час підключення картки емітент додатково перевіряє клієнта (SMS/застосунок банку).
Підтвердження операції	SE формує криптограму від DAN, суми, дати, випадкового числа; еквайр надсилає її через платіжну систему; TSP детокенізує DAN у PAN, перевіряє криптограму та домен (цей пристрій, NFC або e-commerce); емітент авторизує операцію за звичайними правилами (баланс, ліміти, антифрод).

Аспект	Apple Pay
Криптографічні механізми	Мережева токенізація EMV; симетрична криптограма на ключах SE (аналог ARQC); захищене апаратне сховище (Secure Element, Secure Enclave); NFC-транзакція EMV contactless; для в Інтернеті — гібридне шифрування ECIES (ECDH + AES-GCM) на відкритий ключ процесингового сертифіката продавця і цифровий підпис Apple; TLS для всіх мережевих каналів.
Характерні загрози	Додавання вкраденої картки в гаманець зловмисника (слабка перевірка при підключенні — ID&V емітента); соціальна інженерія з метою отримати код підключення; крадіжка пристрою з відомим кодом пароля; шкідливий застосунок/сайт, що ініціює платіж на іншу суму (протидія — відображення суми в системному вікні Apple Pay); релейні атаки на NFC (обмежуються вимогою біометрії, крім режиму Express Transit); компрометація серверів продавця — лише DAN, непридатний без криптограми.

Таблиця 4 — Аналіз Apple Pay

Коротке пояснення. Безпека Apple Pay ґрунтується на трьох ідеях: (1) PAN замінюється прив’язаним до пристрою токеном DAN, тому витік у продавця чи перехоплення не розкриває реквізити картки; (2) кожна операція підтверджується одноразовою криптограмою, яку може сформувати лише SE з секретними ключами — повтор неможливий; (3) автентифікація відбувається локально на апаратно захищеному пристрої (біометрія + володіння) і вбудована в сам акт оплати. Найбільш вразливим етапом залишається підключення картки до гаманця, тому саме там емітенти застосовують додаткову перевірку.

6. Історичний криптографічний протокол: SET

Як індивідуальний варіант історичного протоколу обрано **SET (Secure Electronic Transaction)**.

6.1. Задача, для якої запропоновано SET

SET розроблено Visa і MasterCard за участі IBM, Microsoft, Netscape, RSA, VeriSign та ін. (1996 р., специфікація 1.0 — 1997 р.) для безпечних карткових платежів у відкритих мережах. Протокол вирішував три проблеми, які SSL тих років не розв’язував: (1) продавець не повинен бачити номер картки, а банк — деталі замовлення; (2) усі сторони (покупець, продавець, платіжний шлюз) мають бути взаємно автентифіковані; (3) операція має бути цілісною і неспростовною.

6.2. Принцип роботи

Кожен учасник мав сертифікат X.509v3 в ієрархії ЦС платіжної системи (Root CA → Brand CA → Cardholder / Merchant / Payment Gateway CA). Покупець використовував спеціальну програму-гаманець. Під час купівлі він формував **інформацію про замовлення (OI)** для продавця та **платіжну інформацію (PI)** з номером картки для платіжного шлюзу еквайра, підписував їх **подвійним підписом** і шифрував PI на відкритий ключ шлюзу. Продавець перевіряв підпис і пересилав

зашифрований PI шлюзу; шлюз розшифровував PI, перевіряв підпис і виконував авторизацію через банківську мережу, а відповідь підписувалася і поверталася продавцю.

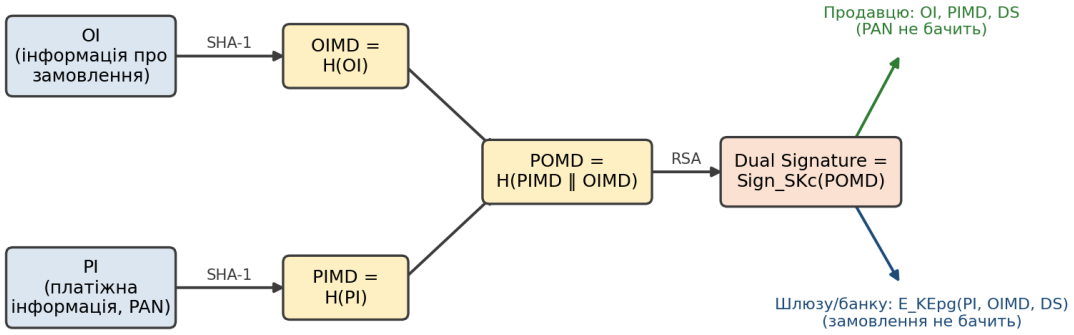


Рисунок 3 — Формування подвійного підпису SET

6.3. Криптографічні механізми

- **Подвійний підпис (dual signature):** DS = Sign(H(H(PI) ‖ H(OI))). Зв'язує замовлення та оплату так, що кожна сторона може перевірити підпис, маючи лише свою частину даних і хеш іншої.
- **Цифровий конверт:** дані шифруються симетричним ключем (DES), ключ — відкритим ключем RSA одержувача.
- **Цифрові підписи RSA** (1024 біти для учасників, 2048 — для кореневого ЦС) і **хеш-функція SHA-1**.
- **Інфраструктура відкритих ключів** з сертифікатами для всіх учасників, включно з держателями карток; у сертифікаті держателя замість PAN — хеш PAN з секретним значенням.

6.4. Властивості безпеки

Властивість	**Як забезпечується в SET**
Конфіденційність платіжних даних	PI зашифровано на ключ шлюзу — продавець не бачить PAN
Конфіденційність замовлення	Шлюз/банк отримує лише хеш OI
Цілісність	Цифрові підписи та хеші — будь-яка зміна суми чи даних виявляється
Автентифікація сторін	Сертифікати покупця, продавця і шлюзу — взаємна автентифікація
Неспростовність	Покупець не може заперечити, що підписав саме це замовлення і цю оплату
Зв'язування замовлення й оплати	Подвійний підпис: PI не можна приєднати до іншого OI

Таблиця 5 — Властивості безпеки SET

6.5. Порівняння з сучасними механізмами

Ідея SET	Сучасний аналог	Відмінність
Продавець не бачить PAN (PI зашифровано для шлюзу)	Hosted-форми та iframe PSP, токенізація, зашифрований токен Apple Pay/Google Pay на ключ процесора	Досягається інфраструктурою PSP без криптографії на стороні покупця
Сертифікат і підпис держателя картки	3-D Secure 2 та SCA: автентифікація емітентом через застосунок банку, FIDO/passkeys, біометрія пристрою	Ключі живуть у смартфоні/SE, а не в окремому гаманці; немає потреби в PKI для мільйонів держателів
Динамічний підпис кожної операції	Криптограми EMV/токенів, CAVV, динамічне зв'язування за постановою НБУ № 58	Симетрична криптографія в захищеному апаратному модулі замість RSA-підпису на ПК
Автентифікація продавця і шлюзу сертифікатами	TLS з сертифікатами WebPKI, mTLS між PSP і платіжною системою, API-ключі й HMAC	Канальний захист + прикладні підписи
Власна PKI платіжної системи	PKI для 3DS Directory Server, Apple Pay Merchant ID, TSP	Сертифікати видаються організаціям, а не кінцевим користувачам

Таблиця 6 — Порівняння ідей SET із сучасними механізмами

SET не набув поширення через складність: встановлення гаманця, видачу сертифікатів кожному держателю, обчислювальні витрати (RSA на ПК 1990-х), вартість впровадження для продавців і банків, а також через конкуренцію з простішим SSL. Проте його ключові ідеї — поділ доступу до даних між учасниками, автентифікація держателя, криптографічне зв'язування операції з її параметрами — реалізовані в сучасних системах іншими засобами: токенізацією, 3-D Secure 2, мобільними гаманцями з апаратними сховищами ключів.

7. Висновки

1. Картковий платіж в Інтернеті — багатосторонній процес (покупець, продавець, PSP/еквайр, платіжна система, емітент), у якому різні дані потребують різного захисту на різних етапах. Ключові рішення ухвалює емітент: він автентифікує платника (3-D Secure, SCA) і авторизує операцію.

2. TLS необхідний, але не достатній: він захищає лише канал між двома вузлами. Повний захист забезпечує комбінація механізмів — токенізація (знецінення даних при зберіганні), заборона зберігання CVV2, 3-D Secure та посилена автентифікація (перевірка платника), HMAC/цифрові підписи з nonce і мітками часу (цілісність і захист від повтору на рівні повідомлень), EMV-криптограми та динамічне зв'язування (прив'язка до суми й отримувача), вимоги PCI DSS до всієї інфраструктури.

3. Аналіз ситуацій порушення безпеки показав: коректний TLS залишає спостерігачу лише метадані; токенізація зводить наслідки витоку бази продавця до

мінімуму; повтор і модифікацію запитів виявляють HMAC/підпис разом з nonce і часовими мітками, що підтверджено практичною демонстрацією. Багатофакторна автентифікація та 3-D Secure нейтралізують крадіжку пароля, але не соціальну інженерію, фішинг у реальному часі й шкідливе ПЗ на смартфоні.

4. Постанова НБУ № 58 впроваджує в Україні вимоги, аналогічні європейській PSD2: два незалежні елементи різних категорій, динамічне зв’язування з сумою та отримувачем, обмеження спроб і сесій, вичерпний перелік винятків.

5. Apple Pay реалізує сучасний підхід: мережева токенізація, одноразові криптограми, апаратне сховище ключів і локальна біометрична автентифікація; PAN не зберігається ні на пристрої, ні в Apple, ні в продавця. Ці механізми втілюють ідеї історичного протоколу SET — поділ доступу до даних, автентифікацію держателя картки та криптографічне зв’язування операції — значно зручнішим для користувача способом.

8. Перелік використаних джерел

1. Постанова Правління Національного банку України від 03.05.2023 № 58 «Про затвердження Положення про автентифікацію та застосування посиленої автентифікації на платіжному ринку». URL: https://zakon.rada.gov.ua/go/v0058500-23
2. Закон України «Про платіжні послуги» від 30.06.2021 № 1591-IX.
3. PCI Security Standards Council. Payment Card Industry Data Security Standard v4.0.1. 2024. URL: https://www.pcisecuritystandards.org/
4. EMVCo. EMV 3-D Secure Protocol and Core Functions Specification v2.3.1. URL: https://www.emvco.com/emv-technologies/3-d-secure/
5. EMVCo. EMV Payment Tokenisation Specification — Technical Framework v2.3. URL: https://www.emvco.com/emv-technologies/payment-tokenisation/
6. Apple. Apple Platform Security Guide: Apple Pay. URL: https://support.apple.com/guide/security/
7. Apple Developer. Payment Token Format Reference. URL: https://developer.apple.com/documentation/passkit/payment-token-format-reference
8. Visa, MasterCard. SET Secure Electronic Transaction Specification. Book 1: Business Description; Book 3: Formal Protocol Definition. 1997.
9. Stallings W. Cryptography and Network Security: Principles and Practice. 8th ed. Pearson, 2020. (розділ про SET).
10. Krawczyk H. et al. HMAC: Keyed-Hashing for Message Authentication. RFC 2104. IETF, 1997.

11. ISO 8583-1:2003. Financial transaction card originated messages — Interchange message specifications.
12. Directive (EU) 2015/2366 (PSD2) i Commission Delegated Regulation (EU) 2018/389 (RTS on SCA).
13. Rescorla E. The Transport Layer Security (TLS) Protocol Version 1.3. RFC 8446. IETF, 2018.